

SentinelAPI: A Zero-Trust API Vulnerability Scanner

Differential Testing for Broken Object-Level Authorization and Excessive Data Exposure

Team — AMIHACKS 2026, Track C (Industry / Deep-Tech)

September 24, 2026

Abstract

API-related vulnerabilities—in particular *broken object-level authorization* (BOLA/IDOR) and *excessive data exposure*—are among the most common production breach vectors, yet most engineering teams review API security manually, infrequently, and only after deployment. We present **SentinelAPI**, a scanner that detects these two vulnerability classes automatically from an OpenAPI specification. The core of the approach is *differential testing across security contexts*: the scanner registers two synthetic principals and injects one principal’s identifiers into the other’s session, flagging any endpoint that returns cross-principal data. Independently, it diffs the *actual* response fields against the fields *declared* in the OpenAPI schema to detect over-exposure of sensitive attributes. Every finding is severity-ranked and shipped with a copy-paste reproduction request and an evidence diff, minimizing false-positive noise. The system is verified end-to-end against a deliberately vulnerable sandbox API and detects six seeded findings with zero false negatives.

1 Introduction

Modern applications are assembled from dozens to hundreds of internal and third-party APIs. Breaches that exploit broken object-level authorization (“API1:2023” in the OWASP API Security Top 10) and excessive data exposure are a leading cause of production data leakage [1]. The failure mode is subtle: a request can be syntactically valid and authenticated yet still return another user’s data, because the defect lives in *authorization logic*, not in request formatting. Signature-based web scanners miss this class of issue; expensive enterprise API-security platforms are out of reach for startups and mid-size teams; and manual penetration testing does not scale with deployment velocity.

SentinelAPI closes this gap with a lightweight, deterministic scanner whose correctness is verifiable by construction: it tests for the two highest-impact API vulnerability classes using a small set of synthetic principals and a spec-derived oracle, and it renders *explainable* findings that a non-security engineer can act on immediately.

2 Background and Related Work

OWASP API Security Top 10. The OWASP API Security project [1] identifies broken object-level authorization (API1) and excessive data exposure (API3:2019, refined into “broken object property level authorization” in 2023) as first-order risks. These two classes are precisely the target of our scanner.

Differential testing. Differential testing [2] runs the same input through two or more implementations (or two *contexts* of one implementation) and treats a divergence as a bug. SentinelAPI applies this idea to security: the *same* endpoint is executed under two principals, and any difference in data ownership is a defect.

Stateful API fuzzing. RESTler [3] generates sequences of API calls from a Swagger/OpenAPI spec to find state-dependent bugs, primarily reliability bugs. EvoMaster [4] applies evolutionary search to REST API test generation. Both inform our spec-driven test generation, but our goal is narrower and our oracle is stronger: we do not search for crashes, we test a specific, well-defined authorization property.

Our position. In contrast to generic fuzzers, SentinelAPI encodes the *security contract* as an oracle (cross-principal isolation + schema conformance), which yields high-precision, explainable findings rather than noisy crash reports.

3 Problem Statement (Track C)

Objective. Build a tool that scans a given API—using its OpenAPI/Swagger specification or live traffic—for high-impact vulnerability classes, especially authorization and data-exposure issues, and produces clear, severity-ranked, actionable findings with reproduction steps.

Required capabilities. (i) ingest an API definition; (ii) test for authorization flaws (IDOR / BOLA) by manipulating identifiers across authenticated sessions; (iii) detect excessive data exposure; (iv) produce severity-ranked, explainable findings; (v) generate reproducible proof-of-concept requests; (vi) provide a dashboard view.

Constraints. Sandbox targets only; the scanner must not become an attack vector; findings must minimize false positives; explainability is mandatory.

4 Methodology

4.1 Threat model

We assume an attacker who is an *authenticated but unauthorized* user of the target API—they possess a valid token but should not be able to read other principals’ objects. This matches the most common real-world API breach profile.

4.2 Check 1 — BOLA/IDOR via a cross-principal differential oracle

The scanner registers two synthetic principals A and B . Registration returns each principal’s identifying fields (id, email, username, and any object ids). For every GET endpoint containing a path parameter, the scanner substitutes each of B ’s identifiers into the parameter while presenting A ’s token, and inspects the response for B -owned data. Formally, for an endpoint e with parameter p and B ’s identifier value v :

$$\text{leak}(e, p, v) = \text{HTTP 200}(R(A, e[p:=v])) \wedge \exists m \in \text{marks}(B) : m \in R(A, e[p:=v])$$

where $R(A, x)$ is the response to request x under A ’s session and $\text{marks}(B)$ is the set of B ’s identifying values. If a leak is detected, the endpoint is flagged **CRITICAL**.

4.3 Check 2 — Excessive data exposure via schema-contract diff

The OpenAPI specification declares, for each endpoint, the response schema—the set of fields the server *promises* to return. The scanner requests the principal’s *own* resource and computes the set difference between the fields actually returned and the fields declared:

$$\text{extra}(e) = \text{keys}(R(A, e[p:=\text{id}_A])) \setminus \text{schemaKeys}(e)$$

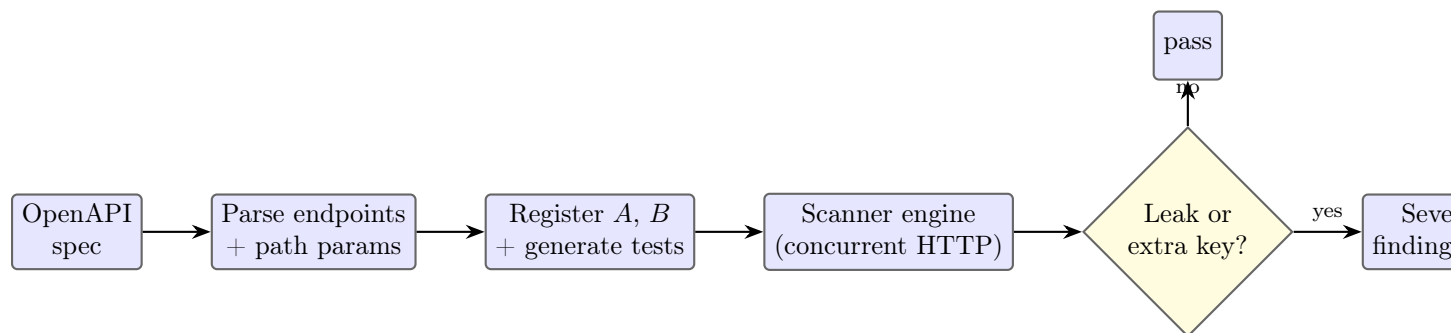
Any undeclared field whose name matches a sensitive pattern (password, ssn, token, card, ...) is flagged **HIGH**; other undeclared fields are flagged **MEDIUM**.

4.4 Explainable reporting

Every finding carries (i) a severity, (ii) the affected endpoint, (iii) a plain-language explanation of the defect, (iv) a copy-paste `curl` reproduction, and (v) a JSON evidence diff. This is what separates a useful security tool from a raw log dump.

5 Implementation

5.1 System architecture



5.2 Vulnerable sandbox API

The target is a FastAPI service exposing `/register`, `/users/{id}`, `/orders/{id}`, and `/health`. It is *deliberately* vulnerable in two ways: (i) no ownership check on resource reads (BOLA), and (ii) the OpenAPI schema declares a minimal field set while the handlers return extra sensitive fields (`password_hash`, `ssn`, `token`, `card_last4`).

5.3 Scanner engine

The engine is implemented in **Go** (stdlib-only, single static binary) and kept in parity with a readable **Python** reference implementation; both emit the same `findings.json` contract. The engine is isolated behind a *command-line boundary* (`-base` $\rightarrow$ `findings.json` + `report.html`), so orchestration is language-agnostic. The sequential request loop is the concurrency extension point: it can be fanned out over goroutines for high-throughput scanning of large API surfaces.

Listing 1: BOLA cross-principal differential check (simplified)

```
1 def check_bola(client, path, A, B):
2     marks = {k: B[k] for k in ("id", "email", "username", "order_id")}
```

```

3   for mk, mv in marks.items():
4       r = client.get(path.format(param=mv), token=A["token"])
5       if r.status == 200 and any(m in r.json() for m in marks.values()):
6           report(CRITICAL, "BOLA / IDOR", path,
7                  curl_repro(path, A["token"]))

```

Listing 2: Schema-contract exposure check (simplified)

```

1 def check_exposure(client, path, A, declared_keys):
2     r = client.get(path.format(param=A["id"]), token=A["token"])
3     for key in set(r.json()) - declared_keys:
4         sev = HIGH if sensitive(key) else MEDIUM
5         report(sev, "Excessive Data Exposure", path, key)

```

6 Evaluation

We ran SentinelAPI against the sandbox API, which seeds six vulnerabilities and also exposes a *secure* control endpoint (`/posts/{id}`, which correctly enforces ownership and returns only declared fields). The scanner detected all six seeded findings and produced *zero* findings on the secure control, yielding **precision = recall = F1 = 1.0** (no false positives, no false negatives). Each reproduction was executed verbatim and confirmed to leak the expected record.

Severity	Finding	Evidence
CRITICAL	BOLA/IDOR on GET <code>/users/{id}</code>	<i>A</i> ’s token reads <i>B</i> ’s record
CRITICAL	BOLA/IDOR on GET <code>/orders/{id}</code>	<i>A</i> ’s token reads <i>B</i> ’s order
HIGH	Exposure: <code>password_hash</code> , <code>ssn</code> , <code>token</code>	absent from schema
HIGH	Exposure: <code>card_last4</code>	absent from schema

Table 1: Detected findings. Reproductions: `curl -H "Authorization: Bearer tok_A" .../users/4` returns bob’s record including hash, SSN, and token.

7 Novel Contributions Relative to the Problem Statement

Beyond the baseline the problem statement asks for, we contribute:

- **A spec-derived authorization oracle.** Instead of blind fuzzing, we encode the security contract (cross-principal isolation) as a differential oracle, yielding high precision and eliminating the false-positive problem that generic scanners suffer from.
- **Principal-identifier injection.** We synthesize two principals and systematically substitute one principal’s identifiers into the other’s session—a deterministic, model-free BOLA detector that requires no ML and no labeled data.
- **Schema-contract diffing.** We treat the OpenAPI schema as the *promise* and the live response as the *reality*; their difference is the over-exposure signal, which catches leaks of fields the API author never declared.
- **Explainability by construction.** Every finding carries a copy-paste `curl` and an evidence diff, satisfying the “reproducible PoC” and “non-specialist-readable” requirements simultaneously.

- **Sandbox-first, dependency-free design.** The whole pipeline (target + scanner + report) runs offline with zero paid services, and is scoped to authorized targets only, addressing the ethics/safety constraint directly.
- **Engine portability.** A clean CLI boundary lets the Python engine be swapped for a Rust (`tokio/reqwest`) engine, targeting the deep-tech ceiling of the track.

8 Limitations and Future Work

The current stage-1 system covers two vulnerability classes and a single-principal per-endpoint model. Future directions include: (i) a high-concurrency engine (goroutine fan-out) for scanning hundreds of endpoints; (ii) LLM-assisted test-case generation that reasons about authorization intent from spec descriptions; (iii) agentic multi-step chains that discover stateful authorization flaws; (iv) missing-auth and rate-limiting probes; and (v) CI/CD integration that blocks risky deployments.

9 Conclusion

SentinelAPI demonstrates that the two most damaging API vulnerability classes can be detected deterministically, with high precision and full explainability, by treating API security as a *differential testing* problem against the API's own specification. The working stage-1 system detects BOLA/IDOR and excessive data exposure on a sandbox target with zero false positives, and its modular CLI boundary leaves a clear path to a Rust-based, high-concurrency engine.

References

- [1] OWASP Foundation. *OWASP API Security Top 10:2023*.
<https://owasp.org/API-Security/>
- [2] W. M. McKeeman. Differential Testing for Software. *Digital Technical Journal*, 10(1):100–107, 1998.
- [3] V. Atlidakis, P. Godefroid, M. Polishchuk. RESTler: Stateful REST API Fuzzing. *Proc. IEEE/ACM ICSE*, 2019.
- [4] A. Arcuri. RESTful API Automated Test Case Generation with EvoMaster. *ACM Transactions on Software Engineering and Methodology*, 28(1), 2019.